

NEIGE & SOLEIL

Application web de gestion locative en station — Client léger (HTML/CSS/JS, PHP, MySQL — architecture MVC)

Documentation des incidents

Procédure de gestion et registre des incidents connus

Champ	Valeur
Projet	Neige & Soleil (client léger)
Document	Documentation des incidents
Version	1.0
Date	8 juin 2026
Statut	Interne

Sommaire

1. Objet du document	3
2. Processus de gestion d'un incident	3
3. Niveaux de gravité	3
4. Modèle de fiche d'incident	3
5. Registre des incidents connus	4
6. Fiches détaillées	5
INC-001 — Injection SQL (requêtes concaténées en PHP)	5
INC-002 — Mots de passe en clair	5
INC-003 — Identifiants MySQL codés en dur	6
INC-004 — Mise à jour du profil sans effet	6
INC-005 — Absence de contrôle d'accès par rôle	7
INC-006 — Calcul de facture incohérent	7
INC-007 — Logo non affiché	8
INC-008 — Connexion BDD à chaque requête	8
INC-009 — Message de bienvenue mal formaté	8
7. Note sur la confidentialité	9

1. Objet du document

Ce document décrit la procédure de gestion des incidents de l'application web Neige & Soleil (client léger) et tient à jour un registre des incidents connus, avec leur gravité, leur impact, leur contournement et la correction recommandée. Il sert de référence au support et aux développeurs.

2. Processus de gestion d'un incident

1. Détection : l'utilisateur ou le support constate un dysfonctionnement.
2. Enregistrement : ouverture d'une fiche d'incident (modèle au §4).
3. Qualification : attribution d'un niveau de gravité et d'un domaine concerné.
4. Diagnostic : analyse de la cause (vue HTML/CSS/JS, contrôleur PHP, modèle / base de données MySQL, sécurité).
5. Traitement : mise en place d'un contournement immédiat puis d'une correction durable.
6. Clôture : vérification, information de l'utilisateur et archivage de la fiche.

3. Niveaux de gravité

Niveau	Définition	Délai cible
Critique	Perte de données, faille de sécurité ou application inutilisable.	Immédiat
Majeur	Fonction essentielle indisponible ou résultat erroné.	24 h
Mineur	Gêne sans blocage ; contournement possible.	5 jours
Cosmétique	Défaut d'affichage ou de libellé.	Selon planning

4. Modèle de fiche d'incident

Rubrique	À renseigner
Identifiant	INC-AAAA-NNN
Date / Heure	Date et heure de détection
Déclaré par	Nom de l'utilisateur ou du support
Module concerné	Authentification, Réservation, Facture, Vue, Contrôleur, Modèle, etc.
Gravité	Critique / Majeur / Mineur / Cosmétique
Description	Symptôme observé et étapes pour le reproduire
Cause identifiée	Origine technique du problème
Contournement	Solution temporaire pour l'utilisateur
Correction	Action durable à mener et statut
Statut	Ouvert / En cours / Résolu / Fermé

5. Registre des incidents connus

Les incidents ci-dessous ont été identifiés lors de la revue de l'application. Ils doivent être traités par priorité de gravité.

ID	Module	Gravité	Synthèse
INC-001	Modèle / Données	Critique	Requêtes SQL construites par concaténation en PHP — risque d'injection SQL.
INC-002	Sécurité	Critique	Mots de passe stockés et comparés en clair en base MySQL.
INC-003	Configuration	Critique	Identifiants MySQL codés en dur dans le code (compte root sans mot de passe).
INC-004	Profil	Majeur	La mise à jour du profil ne fonctionne pas (identifiant utilisateur non transmis).
INC-005	Accès / Contrôleur	Majeur	Aucun contrôle d'accès par rôle côté serveur : toutes les pages accessibles à tous.
INC-006	Facture	Majeur	Calcul de facture incohérent entre prix hebdomadaire et durée en jours.
INC-007	Vue / Affichage	Mineur	Logo non affiché selon la page (chemin d'image relatif).
INC-008	Performance	Mineur	Nouvelle connexion MySQL ouverte à chaque requête.
INC-009	Vue / Interface	Cosmétique	Message de bienvenue mal formaté (espaces manquants).

6. Fiches détaillées

INC-001 — Risque d'injection SQL

Rubrique	Détail
Gravité	Critique
Module	Modèle — accès aux données (PHP / MySQL)
Description	Les requêtes SQL (authentification, recherches, insertions) sont assemblées par concaténation de chaînes à partir des données reçues via <code>\$_POST</code> / <code>\$_GET</code> . Une saisie malveillante peut altérer la requête exécutée.
Cause	Absence de requêtes préparées ; les valeurs sont injectées directement dans le texte SQL.
Impact	Contournement de l'authentification, lecture ou destruction de données.
Contournement	Restreindre les droits du compte MySQL ; échapper les saisies a minima ; sauvegarder la base régulièrement.
Correction	Remplacer les requêtes concaténées par des requêtes préparées PDO (ou mysqli) avec marqueurs liés (<code>bindParam</code> / <code>bindValue</code>).

INC-002 — Mots de passe en clair

Rubrique	Détail
Gravité	Critique
Module	Sécurité / Authentification (PHP)
Description	Les mots de passe sont enregistrés en clair dans la table des utilisateurs et comparés tels quels lors de la connexion.
Cause	Aucun mécanisme de hachage à l'inscription ni à la vérification.
Impact	Toute personne accédant à la base MySQL lit l'ensemble des mots de passe.
Contournement	Restreindre l'accès à la base ; imposer des mots de passe distincts de ceux d'autres services.
Correction	Stocker une empreinte hachée et salée avec <code>password_hash()</code> (bcrypt / Argon2) et vérifier avec <code>password_verify()</code> .

INC-003 — Identifiants de base de données codés en dur

Rubrique	Détail
Gravité	Critique
Module	Configuration / Connexion BDD (PHP)
Description	Les identifiants de connexion MySQL (hôte, utilisateur <code>root</code> , mot de passe vide) sont écrits en dur dans le script de connexion, versionné et livré avec l'application.
Cause	Paramètres de connexion non externalisés et compte trop privilégié (<code>root</code>).
Impact	Privilèges excessifs et secret exposé dans le code livré.
Contournement	Définir un mot de passe au compte de base ; placer le fichier de connexion hors de la racine web.
Correction	Externaliser les paramètres dans un fichier de configuration hors racine web (ou variables d'environnement) et utiliser un compte applicatif aux droits limités.

INC-004 — Mise à jour du profil sans effet

Rubrique	Détail
Gravité	Majeur
Module	Profil (Contrôleur + Modèle)
Description	La validation du formulaire de profil n'enregistre aucune modification : la page se recharge en affichant les anciennes valeurs.
Cause	L'identifiant de l'utilisateur n'est pas transmis du contrôleur au modèle ; la clause <code>WHERE</code> de l' <code>UPDATE</code> ne cible aucune ligne.
Impact	Les modifications de profil sont silencieusement perdues.
Contournement	Faire modifier le compte par l'administrateur directement.
Correction	Récupérer l'identifiant depuis la session (<code>\$_SESSION</code>), le transmettre au modèle, cibler la bonne ligne (<code>WHERE id = :id</code>) et contrôler le nombre de lignes affectées.

INC-005 — Absence de contrôle d'accès par rôle

Rubrique	Détail
Gravité	Majeur
Module	Accès / Contrôleur
Description	Tous les liens de menu (Personnel, Propriétaires, etc.) et toutes les pages sont accessibles quel que soit le rôle de l'utilisateur ; il suffit de connaître l'URL.
Cause	Le rôle n'est pas vérifié côté serveur dans les contrôleurs ; le masquage est seulement côté affichage (vue / JavaScript), donc contournable.
Impact	Un utilisateur peut accéder à des fonctions qui ne le concernent pas.
Contournement	Sensibiliser les utilisateurs ; limiter la création de comptes.
Correction	Vérifier le rôle dans le contrôleur avant tout traitement et afficher/masquer les menus dans la vue ; le contrôle d'accès doit être effectué côté serveur.

INC-006 — Calcul de facture incohérent

Rubrique	Détail
Gravité	Majeur
Module	Facture (Modèle / logique métier)
Description	Le montant facturé mélange un prix exprimé à la semaine et une durée exprimée en jours, ce qui produit un total erroné.
Cause	Unité de prix (semaine) et unité de durée (jour) non homogènes dans le calcul.
Impact	Montants facturés erronés.
Contournement	Vérifier et recalculer manuellement avant remise au client.
Correction	Harmoniser les unités : calculer un tarif journalier ou un nombre de semaines, et clarifier le libellé affiché dans la vue.

INC-007 — Logo non affiché

Rubrique	Détail
Gravité	Mineur
Module	Vue / Interface (HTML / CSS)
Description	Le logo ne s'affiche pas sur certaines pages selon l'URL consultée (image cassée).
Cause	Image référencée par un chemin relatif qui dépend de l'URL de la page (ex. <code>src="images/logo.png"</code>).
Impact	Défaut d'affichage, sans blocage fonctionnel.
Contournement	Naviguer depuis les pages où le chemin résout correctement.
Correction	Référencer l'image par un chemin absolu depuis la racine du site (ex. <code>src="/assets/img/logo.png"</code>) ou via une constante d'URL de base.

INC-008 — Connexion BDD à chaque requête

Rubrique	Détail
Gravité	Mineur
Module	Performance / Modèle (PHP-MySQL)
Description	Une nouvelle connexion à MySQL est ouverte (puis fermée) à chaque requête exécutée au cours d'un même traitement.
Cause	Absence de réutilisation de la connexion (pas d'instance partagée).
Impact	Surcoût et latence accrue en cas d'usage intensif.
Contournement	Aucun nécessaire pour un usage modéré.
Correction	Réutiliser une connexion unique (instance partagée / singleton dans la couche modèle) ou recourir aux connexions persistantes PDO.

INC-009 — Message de bienvenue mal formaté

Rubrique	Détail
Gravité	Cosmétique
Module	Vue / Connexion
Description	Le message de bienvenue colle nom et prénom sans espace.
Cause	Concaténation de chaînes sans séparateur dans la vue.
Impact	Esthétique uniquement.
Contournement	Aucun.
Correction	Ajouter l'espace séparateur entre prénom et nom dans le gabarit (vue).

7. Note sur la confidentialité

Ce document fait référence à des vulnérabilités de sécurité. Sa diffusion doit rester interne à l'équipe projet et au support tant que les incidents critiques ne sont pas corrigés.